

PREZENTARE DE PRODUS

Sentinel

Agent autonom de securitate pentru servere Linux expuse la internet. Detecție deterministă non-stop, analiză cu AI în timp real, răspuns și administrare din Telegram.

by CryptoITData

Atacul s-a industrializat. Timpul de reacție al apărării a rămas același.

Un server expus nu e „posibil să fie atacat”. E scanat continuu, de programe, din prima oră în care are o adresă publică. Automatizarea a scurtat drastic intervalul dintre publicarea unei vulnerabilități și exploatarea ei în masă — dar nu și intervalul în care o organizație obișnuită apucă să repare.

43

zile — media până la aplicarea unui patch într-o organizație fără proces dedicat

5

zile — intervalul până la exploatarea în masă a unei vulnerabilități nou publicate

38

de zile în care ești descoperit, știind exact ce ai de reparat

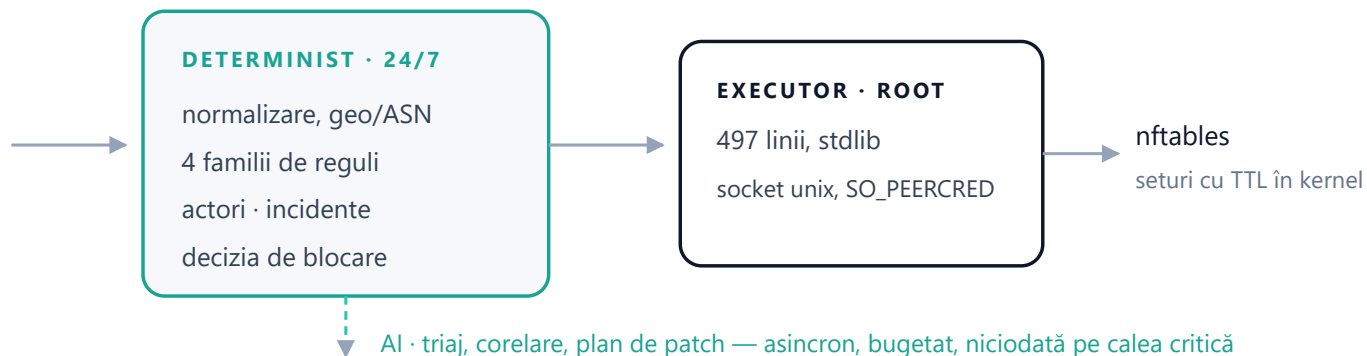
Sursa cifrelor: articolul CryptoITData „Servere expuse la internet în era atacurilor cu AI”.
Diferența dintre cele două numere este motivul pentru care acest produs există.

Un agent care rulează pe serverul tău și nu trimite nimic în afara lui.

Nu este un SIEM, nu este un serviciu cloud și nu instalează un agent care raportează unui terț. Se instalează nativ, sub systemd, cu bază de date locală. Datele tale de securitate rămân pe mașina ta.

SURSE

journald · sshd, sudo, su
nginx / apache access
auditd
Suricata · eve.json



Nu depinde de rețea

Dacă API-ul de AI cade, detecția și blocarea continuă neschimbat.

Nu deschide porturi noi

Botul Telegram trage mesajele. Panoul web stă în spatele nginx-ului tău.

Nu blochează implicit

Pornește în mod „observă” 72 de ore. Vezi ce ar fi blocat, apoi decizi.

Detecția rulează determinist, non-stop, la cost zero pe eveniment.

Regulile nu cer un model și nu cer internet. Consumă evenimentele pe măsură ce apar, construiesc profilul fiecărui actor și decid singure când un tipar devine incident.

Brute-force SSH	fereastră de 10 minute, praguri pe severitate: 8 încercări medium, 25 high, 100 critical
Enumerare web	fereastră de 5 minute pe căi inexistente și tipare de scanare
Alerte Suricata	semnături ET Open, praguri diferite pe severitate
Anomalie de volum	mediană și MAD sezonier, nu medie — traficul de atac distruge media. Scor z de la 3,5 în sus

De ce mediană și MAD

O medie mobilă e trasă în sus chiar de atacul pe care ar trebui să îl semnaleze. După câteva ore de scanare, „normalul” include scanarea. Mediana nu se lasă mutată de valorile extreme.

Perioadă de calibrare: 72 de ore

Pragurile se așază pe traficul tău real înainte ca blocarea automată să fie o opțiune. Un agent care poate bloca trafic fără calibrare e un risc, nu o protecție.

Modelul redactează. Validatorul decide.

Analiza cu AI intră după ce regula a decis, nu înainte. Verdictul modelului se stochează **lângă** cel determinist, niciodată peste el.

CE FACE

- Triaj: citește incidentul serios și explică în română ce e real, ce e zgomot și ce ai de făcut
- Corelare: leagă incidente separate într-o singură campanie
- Redactează procedura de patch, cu backup și rollback
- Raport zilnic și întrebări libere peste propria bază de date

CE NU ARE VOIE

- Să decidă o blocare
- Să execute orice pe server
- Să stea pe calea critică a detecției
- Să depășească bugetul — verificat înainte de fiecare apel

Suprafața de atac pe care o aduce AI-ul. Liniile din log sunt scrise de atacator. Dacă ajung la un model fără precauții, aia e injecție de prompt în propria unealtă de securitate. Sunt tratate ca date neîncredute, transportul e read-only, iar suita de teste plantează **IGNORE PREVIOUS INSTRUCTIONS** într-un access log și verifică să nu se fi executat nimic.

Incidentul ajunge pe telefon în secunde. Răspunsul pleacă tot de acolo.

Nu e un canal de notificări, e consola. Primești incidentul cu butoane de acțiune, blochezi atacatorul cu o apăsare, ceri starea serverului și pornești un patch — fără VPN, fără SSH, fără laptop.

Citare

`/dashboard` • `/status` • `/incidente` • `/vulnerabilitati`
`/servicii` • `/sanatate` • `/evenimente` • `/blocate`
`/patchuri` • `/autoverificare`

Acțiune

`/blocheaza` • `/deblocheaza` • `/rezolva`
`/falspozitiv` • `/liniste` • `/panic`

Fără port deschis

Botul trage mesajele. Nu există endpoint public de falsificat.

Rezistent la cădere

Dacă nginx, TLS-ul sau panoul web cad, canalul rămâne în picioare.

Confirmare dublă

Acțiunile distructive cer o a doua confirmare care restatează ținta.

Butoane cu termen

Token opac, valabil o singură dată; dacă planul se regenerează, butoanele vechi mor.

Ore de liniște

Programabile. Alerte critice și cele de autodiagnostic trec întotdeauna.

Poate bloca trafic. Deci prioritatea de proiectare a fost să nu te blocheze pe tine.

- Tabelă nftables proprie, cu `policy accept`. E o listă de refuz, nu un firewall. O defecțiune nu închide serverul.
- **Blocările nu se persistă.** Un reboot e întotdeauna o ieșire dintr-o blocare făcută din greșeală.
- **Adresa ta intră în allowlist înainte de orice regulă.** Refuzul e impus în executorul root, nu doar în firewall.
- **Expirare în kernel.** Seturile au TTL propriu, deci blocările expiră corect chiar dacă Sentinel e oprit.

Watchdog independent, la 60 de secunde

Rulează ca root, fără nicio dependență de restul aplicației — trebuie să funcționeze exact când tot ce e în jur a căzut. Golește lista de blocări dacă:

- există fișierul `/etc/sentinel/PANIC`
- panoul web e jos de peste 5 minute
- detectorul e în buclă de repornire
- se depășește plafonul de blocări

Plafone în cod, nu în configurație: maximum 60 de blocări pe minut și 20 000 de elemente. Un detector scăpat de sub control nu poate black-hole-ui internetul.

Procedura de reparare se scrie singură. Aplicarea rămâne decizia ta.

Prioritizarea contează mai mult decât scanarea: severitatea se combină cu probabilitatea de exploatare, cu prezența în catalogul de vulnerabilități exploatate activ și cu expunerea reală a serviciului pe mașina ta.

1 · Plan

JSON validat de schemă:
preflight, backup, aplicare,
verificare de sănătate, rollback,
post-verificare.

2 · Validare

Validator determinist.
Comenzile sunt liste de
argumente, niciodată text de
shell. Listă de binare permise,
listă de căi interzise.

3 · Aprobare

Pe Telegram: dry-run, aplică,
respinge, programează.
„Aplică” cere o a doua
confirmare care restatează
ținta și downtime-ul.

4 · Execuție

Pas cu pas, fiecare scris în
jurnal înainte de următorul.
Rollback automat la orice eșec,
cu notificare indiferent de
orele de liniște.

Un plan invalid nu se execută niciodată parțial. Dacă validatorul îl refuză, se regenerează o dată cu erorile reinjectate; dacă și atunci e invalid, se stochează ca respins și nu se atinge serverul. Punctul de restaurare cel mai recent reușit nu se șterge niciodată, indiferent de vechime — nu se elimină singura cale de întoarcere.

Se verifică singur, la fiecare 5 minute, și îți spune când nu funcționează.

Cel mai periculos mod în care cade un produs de securitate este tăcut: serviciul e activ, jurnalul e curat, dashboard-ul se încarcă — și de douăzeci de ore nu mai colectează nimic. Autodiagnosticul a fost construit exact pentru clasa asta de defect.

32

de verificări la fiecare 5 minute, raportate pe Telegram la schimbarea stării

814

teste automate în suită, rulate la fiecare modificare

497

linii în singura componentă care rulează ca root, fără nicio dependență externă

Verificările măsoară **efectul**, nu procesul. Că un serviciu e „activ” nu dovedește nimic. Că un colector a scris un rând, că nucleul chiar ține tabela de blocare, că executorul a răspuns, că baza de date înregistrează ce spune interfața — acelea sunt fapte.

Nu se instalează la fel la doi clienți.

La instalare, Sentinel descoperă ce rulează pe mașină și scrie un inventar pe care îl confirmi tu. Colectorii, regulile și pragurile se ajustează după el.

Site public	colector de acces nginx sau apache, reguli de enumerare, verificări de anteturi și TLS
WordPress / PHP	reguli pentru tiparele de sondare a pluginurilor, corelare cu vulnerabilitățile deschise ale componentelor instalate
Docker	lanțul forward inclus în tabelă — fără el, un atacator „blocat” ar ajunge în continuare la porturile publicate ale containerelor
Bază de date	reguli de acces, verificarea expunerii portului, includere în procedura de backup dinaintea patch-urilor
Sub 2,5 GB RAM	Suricata rulează în mod log-only. Se pierde inspecția de semnături, se păstrează restul — mai bine decât un serviciu care omoară aplicația pe care serverul există ca să o ruleze
Acces din birou	intervalul intră permanent în allowlist. Un singur actor rău dintr-o rețea NAT ar bloca altfel toată clădirea
Flux de volum mare	filtru la nivel de captură pentru telemetrie sau syslog fără valoare de securitate — altfel umple discul

Trei niveluri. Licența e per server.

INSTALARE

Plată unică

Pentru echipe care au deja pe cineva tehnic și vor unealta, configurată corect.

- Evaluare și inventar confirmat
- Instalare pe stack-ul tău, calibrare 72h
- Triaș AI cu verdict în română
- Telegram și panou web propriu
- Documentație de operare

ADMINISTRAT · CEL MAI ALES

Abonament lunar

Pentru firme fără om de securitate dedicat. Noi ne uităm, tu decizi ce se aplică.

- Tot ce e în „Instalare”
- Revizuim incidentele și ajustăm regulile lunar
- Planurile de patch verificate de noi înainte să ajungă la tine
- Raport lunar și actualizări incluse
- Suport la incident, în program

FLOTĂ

Pe bază de proiect

Pentru mai multe servere sau clienți. Configurație per mașină, vedere unificată.

- Tot ce e în „Administrat”, pe fiecare mașină
- Instalare repetabilă din fișier de configurație
- Praguri și excepții per server
- Instruire pentru echipa ta
- SLA negociat

Perioada de calibrare de 72 de ore este inclusă în toate pachetele și nu este opțională.

Ce nu face, spus înainte de contract.

Orice produs de securitate are margini. Un furnizor care nu ți le arată nu înseamnă că nu le are — înseamnă că le vei descoperi singur, la momentul cel mai prost.

- Logurile din interiorul containerelor nu sunt colectate. Se văd evenimentele de rețea și cele ale gazdei, nu ce scrie aplicația în container.
- Nu există monitor dedicat de integritate a fișierelor dincolo de ce oferă auditd.
- Instalarea pe Debian e acoperită de teste, dar nu a fost încă rulată pe o gazdă Debian reală.
- Predicția pe tipare istorice are nevoie de câteva săptămâni de date proprii înainte să însemne ceva.
- Serviciul de mentenanță — retenția partițiilor, agregatele și reîmprospătarea fluxurilor de intelligence — nu este implementat în versiunea curentă. Identificat în producție, în lucru.
- Nu înlocuiește backup-ul, nu înlocuiește un WAF și nu face audit de conformitate.

Ultimul punct e cel mai recent și e cel mai instructiv: a fost găsit de verificarea post-instalare a produsului însuși, nu de un client. Așa arată un proces care funcționează.

Începem cu o discuție, nu cu o factură.

Treizeci de minute, gratuit și fără obligații. Ne spui ce server ai și ce rulează pe el. Îți spunem ce e expus, ce te atacă în momentul ăsta și dacă Sentinel are sens în cazul tău — inclusiv dacă răspunsul e „nu încă”.

Web	cryptoitdata.eu
Programare	cryptoitdata.eu/contact
Documentație tehnică	la cerere, înainte de contract

Sentinel by **CryptoITData**